

Oltalama Saldırıları: Analiz, Temeller ve Önleme Stratejileri

Yönetici Özeti

Bu brifing belgesi, modern siber güvenlik tehditlerinin en yaygın ve etkili türlerinden biri olan oltalama (phishing) saldırılarını tüm yönleriyle ele almaktadır. Oltalama, saldırganların güvenilir bir varlık gibi görünerek kurbanları hassas bilgileri ifşa etmeye, sahte bağlantılara tıklamaya veya kötü amaçlı ekleri açmaya ikna ettiği bir sosyal mühendislik tekniğidir. Etkili bir savunma stratejisi oluşturmak, bu saldırıların temel mekaniklerini, analiz yöntemlerini ve önleme teknolojilerini anlamayı gerektirir.

Belgenin temel bulguları şunlardır:

- Analiz Süreci:** Şüpheli bir e-postanın analizi, e-posta başlığından (gönderen IP adresi, e-posta adresi, tarih/saat) ve gövdesinden (URL'ler, eklerin hash değerleri) sistematik olarak veri toplamayı içerir. Bu süreçte analistin hiçbir bağlantıya tıklamaması veya eki açmaması kritik önem taşır.
- E-posta Altyapısı:** E-postaların gönderimi SMTP (Simple Mail Transfer Protocol) ile gerçekleştirilirken, alımı ve yönetimi POP3 veya IMAP protokolleri aracılığıyla yapılır. Bu protokollerin işleyişini ve aralarındaki farkları bilmek, e-postanın yolculuğunu anlamada kilit rol oynar.
- Teknik Savunma Mekanizmaları:** E-posta sahteciliğini ve manipülasyonunu önlemek için üç temel kimlik doğrulama standardı mevcuttur:
 - SPF (Sender Policy Framework):** Belirli bir alan adı adına hangi IP adreslerinin e-posta göndermeye yetkili olduğunu doğrular.
 - DKIM (DomainKeys Identified Mail):** E-postanın yetkili bir sunucudan geldiğini ve içeriğinin yolda değiştirilmediğini dijital bir imza ile garanti eder.
 - DMARC (Domain-Based Message Authentication, Reporting, and Conformance):** SPF ve DKIM'i birleştirerek, kimlik doğrulama kontrollerinden geçemeyen e-postalara ne yapılacağına dair bir politika belirler.
- Kurumsal Önlemler:** Teknik kontrollere ek olarak, kuruluşlar e-posta filtreleme, güvenli e-posta ağ geçitleri (SEG), bağlantı yeniden yazma, sandboxing (sanallaştırılmış ortamda test) gibi teknolojileri ve kullanıcı farkındalık eğitimleri ile oltalama simülasyonları gibi insan odaklı stratejileri içeren çok katmanlı bir savunma yaklaşımı benimsemelidir.

Bölüm 1: Oltalama Saldırılarına Giriş

Oltalama, saldırganların hedef sistemlere ilk erişimi sağlamak için kullandığı en yaygın ve etkili yöntemlerden biridir. MITRE ATT&CK Çerçevesi'ne göre, bu saldırı türü hedefleri kandırarak bilgi ifşa etmelerini sağlamayı amaçlar.

Oltalama (Phishing) ve Diğer Kötü Amaçlı E-posta Türleri

Farklı motivasyonlara ve hedeflere sahip çeşitli kötü amaçlı e-posta türleri bulunmaktadır:

- **Spam:** Çok sayıda alıcıya toplu olarak gönderilen istenmeyen e-postalardır. Daha tehlikeli olan varyantı **MalSpam** olarak bilinir.
- **Phishing (Oltalama):** Güvenilir bir kurumdan geliyormuş gibi görünen ve hedefleri hassas bilgileri (şifreler, kredi kartı bilgileri vb.) vermeye ikna etmeyi amaçlayan e-postalardır.
- **Spear Phishing (Hedefli Oltalama):** Oltalama saldırısının daha ileri bir seviyesi olup, belirli bir kişiyi veya kurumu hedef alarak hassas bilgi elde etmeye çalışır.
- **Whaling (Balina Avı):** Hedefli oltalama saldırısına benzer, ancak spesifik olarak C-seviyesi yöneticileri (CEO, CFO vb.) hedefler.
- **Smishing:** Oltalama saldırılarının mobil cihazlara odaklanmış halidir ve özel olarak hazırlanmış kısa mesajlar (SMS) kullanır.
- **Vishing:** Smishing'e benzer şekilde, sosyal mühendislik saldırıları için metin mesajları yerine sesli aramaların kullanılmasıdır.
- **Business Email Compromise (BEC - Kurumsal E-posta Dolandırıcılığı):** Bir saldırganın, bir şirket çalışanının e-posta hesabının kontrolünü ele geçirmesi ve bu hesabı kullanarak diğer çalışanları yetkisiz veya hileli eylemler gerçekleştirmeye ikna etmesidir.

Oltalama E-postalarının Tipik Özellikleri

Oltalama e-postaları genellikle aşağıdaki ortak özellikleri taşır:

- **Sahte Gönderici Adı/Adresi (Email Spoofing):** Gönderici, güvenilir bir kişi veya kurum gibi görünür.
- **Aciliyet ve Panik Hissi:** Konu satırında veya e-posta metninde "Fatura", "Askıya Alındı", "Acil" gibi anahtar kelimeler kullanılarak aciliyet hissi yaratılır.
- **Taklit Tasarım:** E-postanın HTML tasarımı, bilinen ve güvenilir bir kurumun (örneğin Amazon, bankalar) kurumsal kimliğini taklit edecek şekilde hazırlanır.
- **Zayıf Dilbilgisi ve Biçimlendirme:** Profesyonel bir kurumdan gelmesi beklenmeyecek derecede zayıf biçimlendirme veya dilbilgisi hataları içerebilir.
- **Genel Hitaplar:** "Sayın Bay/Bayan" gibi kişisel olmayan, genel hitaplar kullanılır.
- **Gizlenmiş Köprüler (Hyperlinks):** Gerçek hedefi gizlemek için genellikle URL kısaltma servisleri kullanılır.
- **Kötü Amaçlı Ekler:** Meşru bir belge (fatura, rapor vb.) gibi görünen ancak kötü amaçlı yazılım içeren ekler barındırır.

Bölüm 2: E-postanın Anatomisi ve İletim Mekanizması

E-posta Adresinin Yapısı

Bir e-posta adresi (billy@johndoe.com örneğinde olduğu gibi) iki ana bölümden oluşur:

1. **Kullanıcı Posta Kutusu (User Mailbox):** @ işaretinden önceki kısımdır (örneğin, **billy**). Bu, alan adı içindeki belirli bir alıcıyı tanımlar.
2. **Alan Adı (Domain):** @ işaretinden sonraki kısımdır (örneğin, **johndoe.com**). Bu, e-postanın gönderileceği sunucunun veya posta sisteminin adresidir.

Temel E-posta Protokolleri

E-postanın gönderilmesi ve alınması sürecinde üç temel ağ protokolü rol oynar:

- **SMTP (Simple Mail Transfer Protocol):** E-postaların gönderilmesini yönetmek için kullanılır.
- **POP3 (Post Office Protocol):** Bir istemci (örneğin Outlook) ile bir posta sunucusu arasında e-posta aktarımından sorumludur.
- **IMAP (Internet Message Access Protocol):** POP3 gibi, bir istemci ile posta sunucusu arasında e-posta aktarımını sağlar.

POP3 ve IMAP Karşılaştırması

Her ikisi de e-posta alımı için kullanılsa da, POP3 ve IMAP arasında temel işleyiş farkları vardır:

Özellik	POP3 (Post Office Protocol)	IMAP (Internet Message Access Protocol)
Depolama	E-postalar sunucudan tek bir cihaza indirilir ve orada saklanır.	E-postalar sunucuda saklanır ve birden fazla cihaza indirilebilir.
Gönderilen Mesajlar	Gönderilen mesajlar, e-postanın gönderildiği tek cihazda saklanır.	Gönderilen mesajlar sunucuda saklanır.
Erişim	E-postalara yalnızca indirildikleri tek cihazdan erişilebilir.	Mesajlar senkronize edilebilir ve birden fazla cihazdan erişilebilir.
Sunucu Durumu	"E-postayı sunucuda tut" ayarı etkinleştirilmezse, mesajlar cihaza indirildikten sonra sunucudan silinir.	Mesajlar varsayılan olarak sunucuda kalır.

Bir E-postanın Yolculuğu

Bir e-postanın göndericiden alıcıya ulaşma süreci aşağıdaki adımları izler:

1. Gönderici (Alexa), e-posta istemcisinde bir e-posta oluşturur ve "Gönder" düğmesine basar.

2. Göndericinin **SMTP** sunucusu, e-postanın nereye gönderileceğini belirlemek için alıcının alan adıyla (**johndoe.com**) ilişkili bilgileri **DNS**'e sorgular.
3. **DNS** sunucusu, alan adıyla ilgili bilgileri (MX kayıtları vb.) alır ve göndericinin **SMTP** sunucusuna iletir.
4. Göndericinin **SMTP** sunucusu, e-postayı internet üzerinden alıcının posta kutusuna doğru gönderir.
5. E-posta, hedef **SMTP** sunucusuna ulaşana kadar çeşitli aracı **SMTP** sunucularından geçer.
6. E-posta, nihayetinde hedefin **SMTP** sunucusuna ulaşır.
7. Hedef **SMTP** sunucusu, e-postayı alıcının beklediği yerel **POP3/IMAP** sunucusuna yönlendirir.
8. Alıcı (Billy), e-posta istemcisini açar ve istemci, posta kutusundaki yeni e-postaları kontrol etmek için yerel **POP3/IMAP** sunucusunu sorgular.
9. Alexa'nın e-postası, kullanılan protokole bağlı olarak Billy'nin e-posta istemcisine kopyalanır (**IMAP**) veya indirilir (**POP3**).

Bölüm 3: Ortalama E-postası Analizi

Şüpheli bir e-postanın analizi, belirli bilgilerin sistematik olarak toplanmasını gerektirir. Bu bilgiler, e-postanın "ham" (raw) kaynak koduna bakılarak da elde edilebilir.

Analiz İçin Kritik Kontrol Listesi

E-posta Başlığından (Header) Toplanacak Bilgiler

- Gönderen e-posta adresi
- Gönderen IP adresi
- Gönderen IP adresinin ters DNS sorgusu (Reverse Lookup)
- E-posta konu satırı
- Alıcı e-posta adresi (bu bilgi CC/BCC alanlarında da olabilir)
- Yanıtla (Reply-to) e-posta adresi (varsa)
- Tarih/saat

E-posta Gövdesinden (Body) Toplanacak Bilgiler

- Tüm **URL bağlantıları** (URL kısaltma servisi kullanılmışsa, gerçek URL'nin elde edilmesi gerekir)
- Ekin adı
- Ekin **hash değeri** (tercihen SHA256, MD5 de olabilir)

Uyarı: Analiz sırasında e-postadaki hiçbir bağlantıya yanlışlıkla tıklamamaya veya ekleri açmamaya özen gösterilmelidir.

Bölüm 4: Ortalama Saldırılarına Karşı Savunma Mekanizmaları

Kuruluşlar, kullanıcıları kötü amaçlı e-postalardan korumak için çeşitli araçlar ve kontroller kullanır.

Teknik Kimlik Doğrulama Kontrolleri

Bu kontroller, e-postanın kaynağını ve bütünlüğünü doğrulamak için DNS kayıtlarını kullanır.

SPF (Sender Policy Framework)

SPF, bir e-postanın göndericisini doğrulamak için kullanılan bir yöntemdir. Bir alan adı için yayınlanan DNS TXT kaydı, o alan adı adına e-posta göndermeye yetkili IP adreslerinin bir listesini içerir. İnternet Servis Sağlayıcıları (ISP'ler), bu kaydı kontrol ederek bir posta sunucusunun yetkili olup olmadığını doğrulayabilir.

DKIM (DomainKeys Identified Mail)

DKIM, gönderilen bir e-postanın kimliğini doğrulamak için kullanılır. Gönderen posta sunucusu, e-postaya bir dijital imza eklemek için özel bir anahtar (private key) kullanır. Alıcı sunucu, imzanın geçerli olup olmadığını doğrulamak için alan adının DNS kayıtlarında yayınlanan genel anahtarı (public key) alır. İmza eşleşirse, e-postanın gerçekten belirtilen alan adından geldiği ve yolda değiştirilmediği kanıtlanmış olur. DKIM'in avantajı, e-posta yönlendirmelerinden sonra bile geçerliliğini korumasıdır.

DMARC (Domain-Based Message Authentication, Reporting, and Conformance)

DMARC, SPF ve DKIM'in sonuçlarını birleştirerek e-posta kimlik doğrulamasını bir üst seviyeye taşır. Gönderenin alan adının, SPF ve DKIM tarafından doğrulanan alan adlarıyla "hizalı" (aligned) olmasını sağlar. Bu hizalama başarısız olursa, DMARC, alıcı sunucuya DMARC kaydında belirtilen politikaya göre e-postayı nasıl ele alması gerektiğini (örneğin reddet, karantinaya al veya hiçbir şey yapma) bildirir.

Kurumsal Düzeyde Önleme Stratejileri

Modern e-posta sistemleri, ortalama mesajlarını kullanıcılara ulaşmadan önce tespit etmek ve engellemek için çeşitli teknik kontroller kullanır:

- **E-posta Filtreleme:** IP ve alan adı itibarına dayalı filtreleme yaparak şüpheli mesajları engeller veya karantinaya alır.
- **Güvenli E-posta Ağ Geçitleri (SEGs):** Mesajları tarayarak taklit girişimlerini, sahteciliği ve diğer ortalama tekniklerini tespit eder.
- **Bağlantı Yeniden Yazma (Link Rewriting):** Şüpheli veya bilinmeyen URL'leri, sistemin bağlantıyı taraması ve doğrulaması için zaman kazandıran güvenli, yönlendirilmiş bağlantılarla değiştirir.
- **Sanallaştırılmış Ortam (Sandboxing):** Şüpheli bağlantıları veya ekleri, kötü amaçlı davranışları kontrol etmek için güvenli, sanal bir ortamda izole eder ve test eder.
- **Güven ve Uyarı Göstergeleri:** Modern e-posta platformları, kullanıcılara bir mesajın güvenli olup olmadığını anlamalarına yardımcı olan görsel ipuçları (örneğin, "Harici Gönderici" veya "Şüpheli Bağlantı" gibi başlıklar) gösterir.

- **Oltalama Raporlama Mekanizmaları:** Kullanıcıların şüpheli mesajları hızla bildirmelerine olanak tanıyan, e-posta içine entegre edilmiş kolay raporlama seçenekleri sunar.
- **Kullanıcı Farkındalık Eğitimleri:** Çalışanları oltalama girişimlerini, sosyal mühendislik taktiklerini ve güvenli e-posta uygulamalarını tanıma konusunda eğitir.
- **Oltalama Simülasyonları:** Çalışan eğitimini test etmek ve pekiştirmek için kontrollü oltalama kampanyaları düzenler.